Guía P1 — Incidente, evidencia y simulación

Nov 3, 2026 · @Anthony

Lo que te toca

Te toca la noche del ataque: reconstruir qué pasó el 14 de octubre con evidencia rastreable y mostrarlo en la defensa con una simulación. En el equipo eres el analista técnico y el custodio de las evidencias.

Tu parte pesa sobre todo en el bloque de forense (2.5 de 15 puntos). Compartes peso en controles de base de datos con P2 y en contención y recuperación con P3. Además, diriges la presentación de 12 minutos.

En concreto: armas la base de datos sintética, escribes las consultas SQL, llevas el índice de evidencias con sus hashes, reconstruyes la cronología, planteas hipótesis y causa raíz, evalúas cómo respondió la empresa esa noche y construyes la simulación.

Cómo nos repartimos el proyecto

El proyecto se parte en tres frentes que siguen las fases del caso: antes, durante y después del ataque. Cada frente tiene un dueño, pero los hallazgos y la defensa son de los tres.

	P1 · Durante	P2 · Antes	P3 · Después
Tema	Incidente, evidencia y simulación	Planeación, riesgos y controles	Terceros, IA, hallazgos y plan
Papel en el equipo	Analista técnico y custodio de evidencias	Coordinación e integración del informe	Revisión de calidad y cierre
Misiones del caso	C: forense, SQL Server, cronología, causa raíz	A, B y la parte de C sobre accesos, cambios, aplicaciones y móvil	D y E: terceros, privacidad, IA, hallazgos, plan y presupuesto
Alertas que prueba	08	01, 02, 03, 04, 09	05, 06, 07, 10, 11, 12

	P1 · Durante	P2 · Antes	P3 · Después
Evidencias que documenta	E-02, E-03, E-04, E-05, E-07	E-01, E-06	E-08, E-09, E-10
Contradicciones que resuelve	Administrador de BD, Seguridad Informática	Desarrollo	Gerencia de TI, Proveedor cloud, Comité de Auditoría, Continuidad
Preguntas del comité	01, 02, 03, 06, 07	09, 10	04, 05, 08
Carpetas a su cargo	03_Evidencias, 04_SQL y la presentación	01_Informe, 02_Matrices, 07_Referencias	05_Plan y el resumen ejecutivo
Rúbrica que más depende de su parte	Forense 2.5; comparte Controles de BD y Contención	Planeación 1.0, Riesgos 2.0, Controles 2.0	Terceros 1.5, Hallazgos 1.5, IA y seguimiento 1.5; comparte Contención

Los tres escriben su parte del informe, dos borradores de hallazgos y su propio registro de uso de IA. La defensa (1.5 puntos) es de todos, y cada uno responde por su frente.

Tus entregables

Entregas cuatro productos propios, integras dos carpetas compartidas y aportas dos borradores de hallazgos.

Entregable	Dónde queda	Qué lleva
Base sintética y consultas	04_SQL/Analisis_Auditoria.sql, más esquema, datos y diccionario	Diseño lógico, diagrama entidad–relación, datos ficticios y al menos seis consultas SELECT documentadas (proponemos doce)

Entregable	Dónde queda	Qué lleva
Papeles de trabajo y custodia	03_Evidencias/Papeles_Trabajo.pdf y los CSV de evidencia	Índice de evidencias, cadena de custodia, hashes SHA-256 y tus papeles PT-20 en adelante; al final integras también los de P2 y P3
Sección forense del informe	01_Informe, unas 4 páginas	Cronología investigada, hipótesis, análisis de la transferencia y de las 216 órdenes, causa raíz y evaluación de la respuesta de esa noche
Simulación	simulacion_14oct.html y un video de respaldo	La noche del 14 reproducida con los registros sintéticos, en dos corridas
Presentación	06_Comite/Resumen_y_Presentacion.pdf	Estructura, diseño y diapositivas forenses; integras las de P2 y P3
Dos borradores de hallazgos	Se los pasas a P3 con la plantilla D	Temas posibles: detección y atención de alertas, integridad de registros, preservación de evidencia durante la recuperación

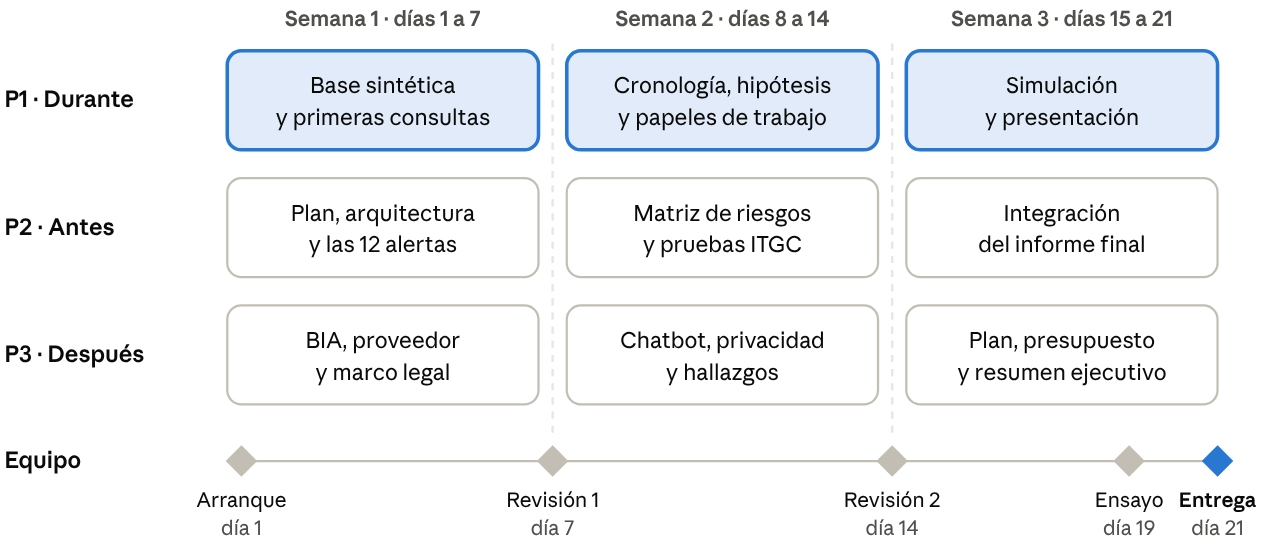
Además le pasas a P2 tus fuentes y tu registro de uso de IA para el anexo del curso.

Tu plan semana por semana

Contamos tres semanas desde la reunión de arranque (día 1) hasta la entrega (día 21). Si la fecha real cae antes, se comprimen las semanas, pero el orden no cambia: primero los datos, luego el análisis y al final la simulación.

Cada semana cierra con una revisión; la entrega es el día 21

Tres frentes en paralelo, contados desde la reunión de arranque



plan del equipo · 3 frentes, 5 hitos

Tu carril va resaltado. Las revisiones de los días 7 y 14 son donde se cruzan las entregas de los tres frentes; si una se mueve, se mueven las de los demás.

Semana 1 · días 1 a 7: la base de datos

- [ ] Día 1: reunión de arranque. Compartir con P2 tu plantilla del informe UdeO y crear la carpeta del equipo con la estructura del curso.
- [ ] Días 1 a 3: diseñar el esquema de la base sintética (tablas, claves, diccionario) y proponer los supuestos S-03, S-04 y S-09.
- [ ] Días 3 a 5: generar los datos ficticios con un script de semilla fija: las señales del caso más actividad normal de fondo.
- [ ] Días 5 y 6: correr Q-01 a Q-04, Q-09 y Q-10; pasar resultados a P2 y P3.
- [ ] Día 6: abrir el índice de evidencias y calcular los primeros hashes.
- [ ] Día 7: revisión 1 con el equipo.

Semana 2 · días 8 a 14: el análisis

- [ ] Correr y documentar Q-05 a Q-08, Q-11 y Q-12.
- [ ] Armar la cronología normalizada y el análisis de relojes; pasar a P3 los tiempos reales de caída a más tardar el día 11.
- [ ] Escribir al menos dos hipótesis, el análisis de los 1.6 GB y de las 216 órdenes, y la causa raíz.

- [ ] Escribir tus papeles PT-20 en adelante (E-02, E-03, E-04, E-05, E-07).
- [ ] Día 12: tus dos borradores de hallazgos a P3.
- [ ] Empezar el prototipo de la simulación con los eventos que saca Q-12.
- [ ] Día 14: revisión 2, con revisión cruzada de hallazgos.

Semana 3 · días 15 a 21: respuesta, simulación y defensa

- [ ] Día 15: cerrar la evaluación de la respuesta de esa noche (contención, recuperación y custodia de la evidencia) y pasar a P3 las acciones de 0–24 h y 24–72 h.
- [ ] Día 16: recibir de P3 las acciones del plan para la corrida 2.
- [ ] Día 17: tu sección del informe a P2; recibir las diapositivas de P2 y P3.
- [ ] Días 17 y 18: cerrar la simulación, armar la presentación completa y grabar el video de respaldo.
- [ ] Día 19: ensayo general, dos veces y con cronómetro.
- [ ] Día 20: hashes finales de todas las evidencias e integración de Papeles_Trabajo.pdf.
- [ ] Día 21: entrega.

Lo que recibes y lo que entregas

Tu base de datos alimenta las pruebas de P2 y la continuidad de P3, así que tus entregas del día 6 y del día 11 son las que más gente espera.

Lo que entregas

Día	Qué	Para
1	Plantilla UdeO del informe (formato de portada y estilos)	P2
6	Base sintética, diccionario y resultados de Q-01 a Q-04 y Q-10 (bajas, privilegios, sesiones, elevaciones, despliegues)	P2
6	Resultado de Q-09 (respaldos) y supuesto S-04 con el horario de respaldos	P3
8	Tus pruebas T-20 en adelante, para el programa de pruebas	P2

Día	Qué	Para
11	Cronología normalizada con los tiempos reales de caída y recuperación	P3
12	Dos borradores de hallazgos	P3
15	Acciones de 0–24 h y 24–72 h que salen de tu evaluación de la respuesta	P3
17	Sección forense del informe, tus fuentes y tu registro de uso de IA	P2
20	Índice de evidencias con hashes finales, para el anexo	P2

Lo que recibes

Día	Qué	De
1	Convenciones y supuestos aprobados en la reunión	Todos
4	Escala de riesgo (S-06) y lista preliminar de riesgos, para vincular tus consultas con R-xx	P2
4	BIA de referencia con RTO y RPO por proceso (S-05)	P3
10	Matriz de riesgos v1 y programa de pruebas, con la numeración de tus pruebas T-20 en adelante	P2
12	Borradores de hallazgos de P2 y P3, para la revisión cruzada	P3
15	Lista consolidada de hallazgos con su código final, para las diapositivas	P3
16	Acciones del plan que entran en la corrida 2 de la simulación	P3
17	Diapositivas de su parte	P2 y P3

Si algo se atrasa, avisa el mismo día en el grupo. Un atraso tuyo el día 6 frena a los otros dos.

La simulación de la noche del 14 de octubre

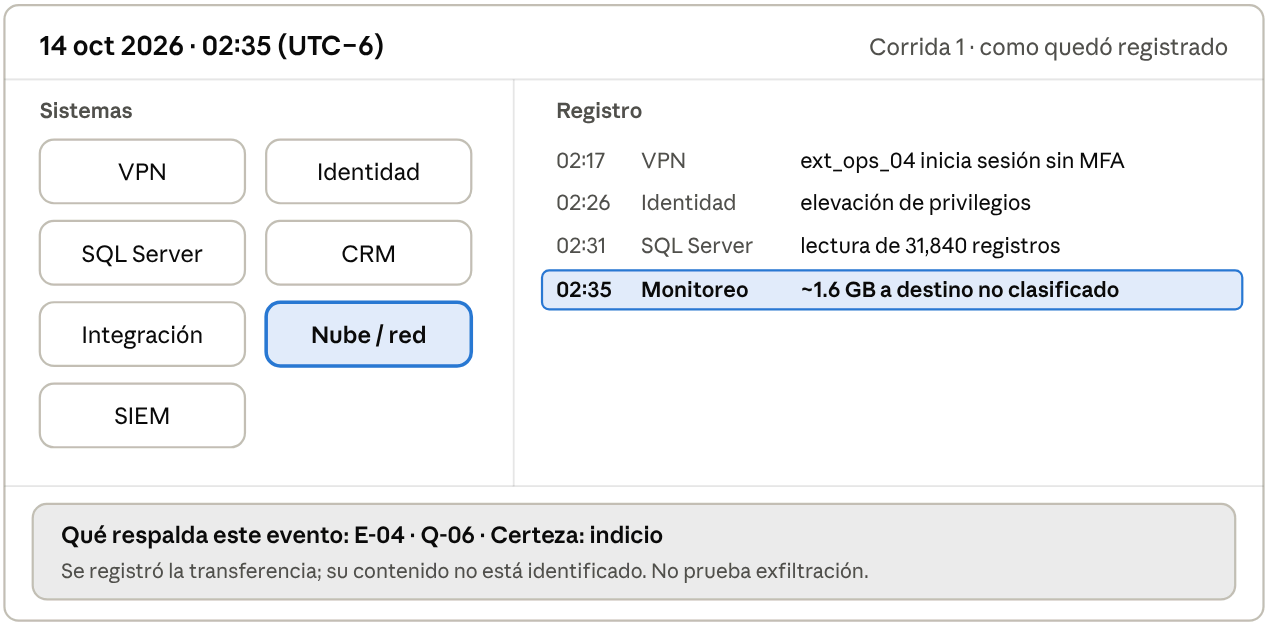
La defensa abre reproduciendo la noche del ataque, evento por evento, con los registros sintéticos del equipo. No es un ataque: es una página que lee datos ficticios y los muestra en orden, junto a la evidencia que los respalda.

Qué se ve en pantalla

- Un reloj que avanza de 02:10 a 11:15 del 14 de octubre, saltando de evento en evento.
- Un mapa sencillo de los sistemas (VPN, identidad, SQL Server, CRM, integración, nube, SIEM) que se ilumina donde ocurre cada evento.
- Una consola con cada registro tal como lo guardó su fuente.
- Un panel que dice qué respalda ese evento: su evidencia (E-xx), la consulta que lo detecta (Q-xx) y si es hecho, indicio o hipótesis.

Cada evento aparece junto a su evidencia y su nivel de certeza

Boceto de la pantalla en la corrida 1, a las 02:35



Espacio: pausa · →: siguiente · 1 y 2: corridas · D: horas originales

pantalla de la simulación · boceto

El panel de abajo es lo más importante: el comité ve en cada paso qué está probado y qué no.

Dos corridas

1. Como quedó registrado: la cadena completa, desde la entrada de ext_ops_04 hasta la recuperación.

2. Con los controles del plan: los mismos eventos con las acciones de P3 funcionando. Se ve dónde se corta la cadena y qué riesgo queda.

Dos detalles que suman

- Una pausa a las 03:42, cuando cae el CRM. Le preguntas al comité si restauraría ya o preservaría evidencia primero; diez segundos y sigues con lo que recomendamos.
- Una tecla que muestra la hora original de cada fuente junto a la normalizada. Con eso respondes la pregunta 06, la de relojes desfasados, sin otra diapositiva.

Por qué vale la pena

En dos minutos muestra la cadena que pide el curso: riesgo, control, prueba, evidencia, hallazgo, acción, verificación y riesgo residual. También deja claro desde el inicio que separamos hechos de hipótesis, que es lo que más va a mirar el comité.

Guion de la corrida 1 (unos 2 minutos)

1. 02:10 · "Miércoles 14 de octubre, dos de la mañana. Vamos a ver lo que quedó en los registros, en el orden en que pasó."
2. 02:17 · "Inicio de sesión por VPN con la cuenta ext_ops_04, sin segundo factor. Es una cuenta externa; desde aquí no sabemos quién estaba detrás."
3. 02:26 · "El servicio de identidad registra una elevación de privilegios."
4. 02:31 · "SQL Server registra una lectura de 31,840 registros de clientes."
5. 02:35 · "Salen cerca de 1.6 GB hacia un destino externo sin clasificar. Es un indicio, no una fuga confirmada: no sabemos qué contenía."
6. 02:42 · "El CRM registra cambios en 216 órdenes."
7. 03:02 · "Se despliega una versión nueva del servicio de integración, sin aprobación formal."
8. 03:18 · "Primera alerta crítica: 61 minutos después del primer evento, y sin cierre documentado."
9. 03:42 · "El CRM deja de responder y aparecen archivos aparentemente cifrados." Pausa: "¿Ustedes restaurarían ya o preservarían evidencia primero?"
10. 04:05 a 09:37 · "TI pide activar recuperación. El CRM vuelve en solo consulta a las 08:57 y con escritura a las 09:37, casi seis horas después de la caída."
11. Cierre · "Eso dicen los registros. No dicen quién usó la cuenta, qué salió en esos 1.6 GB ni si el despliegue tuvo que ver. Para eso hicimos la auditoría." Pasas la palabra a P2.

Corrida 2 (cerca de un minuto; la narra P3 y tú la operas)

Se arma el día 16 con las acciones reales del plan. Un ejemplo de cómo podría sonar: "Misma noche, con el plan funcionando. A las 02:17 la VPN pide segundo factor; si la credencial fue robada, aquí termina. Si quien entró tenía ese factor, la elevación de las 02:26 necesita la aprobación de otra persona. Lo que no desaparece es el abuso de alguien con acceso legítimo: ese es el riesgo residual que pedimos aceptar."

Reglas para que nadie la objete

- Solo datos ficticios: direcciones IP reservadas para documentación (192.0.2.x, 198.51.100.x, 203.0.113.x) y dominios .example.
- Nada de código que cifre archivos, explote algo o se conecte a sistemas reales. La caída del CRM es un cambio de color en pantalla.
- Los eventos salen de la consulta Q-12. Si preguntan de dónde vienen, abres el .sql y lo muestras.
- Se ensaya en la computadora y el proyector de la defensa; si algo falla, pasas al video.

La especificación completa para construirla está en la Tarea 9 de tu documento para el agente.

La defensa de 12 minutos

La defensa empieza y termina con la simulación; en medio, cada uno presenta su frente con tiempos parecidos. Tú la diriges: armas la estructura de diapositivas y llevas el cronómetro en los ensayos.

Minuto	Quién	Qué se muestra
0:00 a 2:00	P1	Corrida 1: la noche del 14 según los registros
2:00 a 5:30	P2	Encargo, alcance y criterios; de las 12 alertas a la matriz; Top 5; controles evaluados
5:30 a 8:00	P1	Cronología normalizada, hipótesis, qué está probado y qué no, causa raíz
8:00 a 11:00	P3	Proveedor, SLA y SOC 2; chatbot; hallazgos priorizados; plan y Q350,000
11:00 a 12:00	P3, con P1 operando	Corrida 2 con el plan funcionando; riesgo residual y decisiones que pedimos al comité

Con 12 a 14 diapositivas alcanza. Las de respaldo (consultas SQL, matriz completa, custodia, marco legal) van al final y solo se abren si preguntan.

En las preguntas, cada uno responde las de su frente, según la tabla del reparto. Si el docente mete evidencia contradictoria de último momento, el dueño del tema dice qué conclusión cambia, cuál se sostiene y qué haría para confirmarlo. En el ensayo, que otro integrante invente dos o tres de esos casos para practicar.

Plan B

- Video MP4 de las dos corridas, en la laptop y en una USB.
- PDF de la presentación con capturas de la simulación.
- Cronología impresa, y el resumen ejecutivo impreso para cada miembro del comité (lo lleva P3).

Convenciones del equipo

Se aprueban en la reunión de arranque y no se cambian sin avisar a los tres. Son las que hacen que el informe se lea como trabajo de un equipo y no de tres personas por separado.

Códigos

Qué	Código	Quién numera
Riesgos y controles	R-01…, C-01…	P2
Pruebas y papeles de trabajo	T-01 a T-19 y PT-01 a PT-19	P2
Pruebas y papeles de trabajo	T-20 a T-39 y PT-20 a PT-39	P1
Pruebas y papeles de trabajo	T-40 a T-59 y PT-40 a PT-59	P3
Evidencias nuevas (E-01 a E-10 son del caso)	E-11 a E-29 / E-30 a E-39 / E-40 a E-49	P1 / P2 / P3; P1 lleva el índice de todas
Consultas SQL	Q-01 a Q-12	P1
Hallazgos	H-01… por prioridad; borradores B1-1, B2-1, B3-1…	P3
Acciones e indicadores del plan	A-01…, K-01…	P3

Qué	Código	Quién numera
Supuestos del equipo	S-01…	P2 lleva el registro
Casos de prueba del chatbot	IA-01…	P3

Palabras con significado fijo

- Hecho confirmado: lo respalda evidencia suficiente y pertinente.
- Indicio: una señal que sugiere algo, pero no lo prueba.
- Hipótesis: una explicación posible, con evidencia a favor y en contra.
- Supuesto del equipo: algo que definimos porque el caso no lo dice; lleva código S-xx.
- No concluyente: lo disponible no alcanza para afirmar ni para descartar.

Nadie escribe "fuga" ni "exfiltración" como hecho mientras no esté probada. Se dice "transferencia de cerca de 1.6 GB hacia un destino externo no clasificado".

Supuestos que se aprueban al inicio

Código	Supuesto	Dueño	Listo el día
S-01	Nube, integraciones/API y soporte los presta un proveedor principal ("el Proveedor"), que usa subcontratistas	P3	1
S-02	Período revisado: controles del 1 de abril al 14 de octubre de 2026; incidente del 12 al 15 de octubre	P2	1
S-03	Hora de referencia: Guatemala (UTC−6), formato de 24 horas	P1	1
S-04	Horario de respaldos y fecha de la última restauración probada	P1	6
S-05	BIA de referencia: RTO, RPO y tiempo máximo tolerable por proceso	P3	4
S-06	Descriptores de probabilidad e impacto, escala de 1 a 5	P2	4
S-07	Tipo de cambio para costos en dólares, con la referencia del Banguat de una fecha fija	P3	15

Código	Supuesto	Dueño	Listo el día
S-08	Escala y umbral del puntaje de riesgo del chatbot (el 0.08 de E-10)	P3	8
S-09	Tamaño de la base sintética, por ejemplo 85,000 clientes ficticios	P1	3

Formato del informe

El de la plantilla UdeO que comparte P1: carta, márgenes de 1 pulgada, Times New Roman 12 justificado, interlineado 1.15, títulos de sección en 13 puntos negrita y tablas con el título "Tabla N." arriba. Citas y bibliografía en APA 7. Números con coma de miles y punto decimal: 31,840 registros, 1.6 GB, Q350,000.00.

Archivos

Una carpeta compartida con la estructura del curso, de 01_Informe a 07_Referencias. Nombres sin tildes ni espacios y con la versión al final, como Matriz_Riesgos_v2.xlsx. Cada quien edita sus archivos; para tocar el de otro, se avisa antes.

Cómo usar tu documento para el agente de IA

El documento para el agente trae el caso resumido, las convenciones, las reglas y diez tareas con lo que necesita para trabajar contigo. Úsalo así:

Tu documento para el agente: Agente IA P1 — Incidente, evidencia y simulación

1. Abre una conversación nueva con el agente y pega el documento completo, o expórtalo a Markdown y adjúntalo. Adjunta también los dos PDFs del curso.
2. Pide una tarea a la vez ("Haz la Tarea 1") y revisa lo que entrega antes de pasar a la siguiente.
3. Trata lo que produzca como borrador: revisa cifras y fuentes, y asegúrate de entender cada consulta y cada conclusión.
4. Al cerrar cada sesión, pídele la entrada del registro de uso de IA. La validación y lo que aprendiste los completas tú, no el agente.
5. Si inventa algo (una norma, una versión, un resultado), corrígelo y anótalo en el registro; eso también cuenta como validación.

La declaración de uso de IA es un entregable del curso, así que el registro se lleva desde el primer día y no se arma al final.

Lo que debes poder explicar sin leer

En la defensa preguntan a cada integrante por separado, y el docente puede cambiar la evidencia en el momento. Si puedes explicar cada punto con tus palabras y un dato del caso, estás listo.

1. Por qué la secuencia de las 02:17 a las 03:42 no prueba por sí sola que un evento causó el siguiente, y qué lo probaría (pregunta 02).
2. Qué falta para afirmar que los 1.6 GB fueron exfiltración: contenido, destino, equipo de origen, comparación con días normales y relación con la lectura de 31,840 registros (pregunta 01).
3. Qué falta para atribuir los 216 cambios de órdenes: quién estaba detrás de la cuenta, desde qué equipo, con qué sesión y contra qué respaldo se comparan (pregunta 03).
4. Cómo se normalizaron las horas de cada fuente y qué margen de error queda (pregunta 06).
5. Qué harías si recuperar el servicio de inmediato pone en riesgo la cadena de custodia (pregunta 07).
6. Qué hace cada consulta núcleo (Q-01, Q-02, Q-03, Q-07, Q-08, Q-09), qué sugiere su resultado y qué no prueba.
7. Por qué las consultas se corrieron con un usuario de solo lectura y para qué sirve un hash SHA-256 en la custodia.
8. Tus hipótesis, con la evidencia a favor y en contra de cada una.
9. Por qué los datos sintéticos no arreglan el resultado: reproducen las señales del expediente, y lo que se agregó está declarado como supuesto.
10. Cómo respondes a las dos contradicciones de tu frente: el administrador de BD que da los datos por intactos sin conciliación terminada, y Seguridad, que llama fuga a una transferencia de contenido desconocido.
11. Que la simulación solo reproduce registros ficticios, y de qué consulta salen sus eventos.

Revisión final antes de entregar

Marca cada punto el día 20, antes de pasarle todo a P2.

- [ ] La base sintética no tiene datos reales: nombres generados, sin DPI, IP de documentación y dominios .example.
- [ ] El .sql corre desde cero sin errores: esquema, datos y consultas, en ese orden.

- [ ] Hay al menos seis consultas SELECT documentadas con objetivo, resultado, interpretación y límite.
- [ ] Hay una captura que muestra las consultas corriendo con el usuario de solo lectura.
- [ ] El índice de evidencias está completo: origen, fecha, custodio, método de obtención y hash de cada archivo.
- [ ] La cronología trae fuente, hora original, hora normalizada, fiabilidad y nivel de certeza en cada fila.
- [ ] Hay al menos dos hipótesis con evidencia a favor y en contra, y en ningún lugar dice "exfiltración confirmada" sin prueba.
- [ ] La sección forense cabe en unas 4 páginas y sus cifras coinciden con las del .sql y los papeles de trabajo.
- [ ] La simulación se probó en la computadora y el proyector de la defensa, y el video de respaldo está en la USB.
- [ ] Tu registro de uso de IA y tus fuentes ya están en manos de P2.